Backlog - Sécurité Android

PO : Wael MEGUEBLI
wmeguebli@esiee-it.fr

Présentation du projet

Vue d’ensemble du projet

Projet : Analyse et sécurisation d’une application Android — de la récupération jusqu’au reporting et à la politique mobile.

Objectifs pédagogiques :

Savoir récupérer un APK vulnérable, faire de l’analyse statique (manuelle + outils automatisés), décompiler/recompiler/Signer un APK, détecter fuites (strings.xml, Firebase…), produire un rapport de vulnérabilités et définir des mesures organisationnelles (politique mobile + choix MDM).

Recommandations organisationnelles

- Groupe de 3 personnes.
- Rédaction du rapport de groupe.

Ce qui est attendu

1) Une démonstration de chaque user story que vous aurez réalisée (environ 30 minutes par groupe).

2) Un dossier par story sur Github

3) Un rapport complet

Stories

US 1: Téléchargement et vérification de l’APK

EN TANT que testeur

JE VEUX recevoir l’APK vulnérable déjà fourni par le PO

AFIN DE travailler sur une base commune

DoD Chaque étudiant vérifie le hash avec sha256sum app.apk et documente le résultat.

US 2 : Analyse automatisée avec MobSF

EN TANT que analyste

JE VEUX scanner l'APK avec MobSF

AFIN DE identifier rapidement métadonnées et vulnérabilités

DoD mobSF_report.pdf + résumé des vulnérabilités.

US 3 : Extraction de fichiers

EN TANT que reverse-engineer

JE VEUX extraire classes.dex / Manifest.xml de l'APK

AFIN DE préparer une décompilation

DoD fichiers livré avec hash SHA256.

Story 4 : Décompilation avec Apktool

EN TANT que auditeur
JE VEUX décompiler l'APK avec Apktool
AFIN DE accéder aux ressources et au manifest

DoD : Dossier app_src/ livré (zippé).

Story 5 : Analyse de strings.xml

EN TANT que analyste sécurité
JE VEUX analyser strings.xml
AFIN DE repérer secrets ou informations critiques en clair.

DoD : strings_findings.md avec extraits (≤25 mots) et risques associés.

Story 6 : Recompilation de l'APK

EN TANT que développeur
JE VEUX recompiler l'APK avec Apktool
AFIN DE vérifier que la décompilation est réversible

DoD : fichier livré + log de build.

Story 7 : Signature de l'APK

EN TANT que testeur

JE VEUX signer l'APK recompilé

AFIN DE pouvoir l'installer sur un émulateur ou terminal

DoD : rebuilt_signed.apk livré + preuve apksigner verify

Story 8 : Vérification Firebase

EN TANT que pentesteur

JE VEUX tester l’accès public à une éventuelle base Firebase

AFIN DE évaluer le risque de fuite de données

DoD : firebase_check.md + capture de la réponse

Story 9 : Rapport technique

EN TANT que consultant sécurité

JE VEUX rédiger un rapport structuré

AFIN DE présenter findings, preuves et recommandations

DoD : rapport_final.pdf livré

Story 10 : Politique de sécurité mobile

EN TANT que responsable sécurité

JE VEUX proposer une politique mobile

AFIN DE encadrer le développement et l'usage des apps mobiles

DoD : politique_mobile livré

Story 11 : Choix d'une solution MDM

EN TANT que architecte sécurité

JE VEUX comparer 2 solutions MDM

AFIN DE recommander la plus adaptée

DoD : mdm_recommandation livré avec tableau comparatif.

Story 12 : Installation MDM & enrôlement d'un smartphone (bonus)

En tant que administrateur IT

Je veux installer une solution MDM choisie et enrôler un smartphone

Afin de appliquer et vérifier une politique de sécurité sur un terminal mobile

DoD : Un device enrôlé est visible dans la console avec statut conforme. Des captures écran montrent l'application réussie de la politique sur le smartphone.

QUESTIONS ?

ESIEE[it]
L'école de l'expertise numérique

une école de la
CCI PARIS ILE-DE-FRANCE

www.esiee-it.fr

M. MEGUEBLI Wael
Enseignant en cybersécurité
wmeguebli@esiee-it.fr